

Cybersecurity Operations Project

Prepared by:

Ghaidaa Algarni - 44411628

Ghala Alzahrani – 444006938

Ghaida Almasoudi – 444002841

Leen Jambi – 444003007

Yousra Balto - 443001942

Part 1: Introduction to the Bank and Its Operational Context

1.1 Bank Overview

The Saudi Investment Bank (SIB) is a major financial institution in the Kingdom of Saudi Arabia, established to provide comprehensive financial services for individuals, companies, and investments. SIB is one of the leading financial institutions in the country, relying on a wide network of branches and digital platforms to deliver its services. Key features include extensive coverage across most regions of the Kingdom through advanced branches, sophisticated digital platforms (including online banking services and mobile applications), and specialized financial services for corporate and investment clients in compliance with local and international regulations.

1.2 Scope of Operations and Services

The bank's operations are divided into three main areas:

1. **Retail Banking Services:** Includes managing bank accounts, offering personal loans and consumer financing, and supporting branches and direct customer service. The focus is on protecting customers' personal data in accordance with the Personal Data Protection Law (PDPL).
2. **Digital Banking and Payment Systems:** Includes online and mobile banking applications, electronic payment gateways, digital money transfers, and card/payment systems including instant transfers (e.g., SWIFT). The main focus is on continuous availability and safeguarding data against cyber fraud.
3. **Corporate and Investment Services:** Includes managing high-value transactions and large investments, financial analysis, asset management, and investment consulting for local and international companies. It also provides specialized services for large institutions and other banks within a regulatory compliance framework.

1.3 Importance of Cybersecurity for the Bank

The Saudi Investment Bank faces critical security challenges that require a robust cybersecurity program to ensure business continuity, customer trust, and regulatory compliance. The primary goal is to ensure the **Confidentiality, Integrity, and Availability (CIA triad)** of sensitive financial information. This commitment protects customers' financial and personal data, including account balances and transaction history, while complying with local regulations such as the PDPL and the SAMA cybersecurity framework. Ensuring continuous digital banking services is also vital, as any downtime can result in significant financial losses and erosion of customer trust.

1.4 Operational Challenges in the Saudi Context

Key challenges include strict compliance with local and international regulations such as SAMA, PDPL, and PCI DSS for card payments. Additionally, the bank faces a high level of cyber threats, including financial fraud and service disruption. Ensuring business continuity (BC) is an ongoing challenge, requiring critical systems to remain continuously operational.

Part 2: Asset Identification and Classification

2.1 Introduction

Critical information assets (CIAs) are resources containing data or functions essential to the bank. Asset classification helps determine the level of protection required for each asset based on the CIA triad (Confidentiality, Integrity, Availability).

2.2 Critical Assets and Protection Requirements

- **Core Banking Ledger:** The primary source of financial information for the bank. Requires high confidentiality, integrity, and availability. Business classification: Confidential; FIPS-199 impact: High. Any breach leads to direct financial losses and regulatory violations.
- **Payment Gateway and SWIFT Systems:** Responsible for processing financial transfers and payments. Also require high confidentiality, integrity, and availability. Business classification: Confidential; FIPS-199 impact: High. Subject to PCI DSS; downtime results in severe financial losses.
- **Customer Relationship Management (CRM) System:** Contains customers' personally identifiable information (PII) and support data. Requires high confidentiality and medium integrity and availability. Business classification: Confidential; FIPS-199 impact: Moderate. Must be protected under PDPL to avoid regulatory fines.
- **Internal Audit and Compliance Reports:** Sensitive reports documenting system and operational audits. Require high confidentiality and integrity. Business classification: Internal; FIPS-199 impact: Moderate. Maintaining integrity is crucial to ensure regulatory reporting accuracy.
- **Investor Relations Website:** Publishes annual reports, stock data, and press releases. Requires low confidentiality and integrity but high availability. Business classification: Public; FIPS-199 impact: Low. Must prevent misleading content that could affect the bank's reputation.

2.3 Classification Based on Required Protection

- **Confidential:** Disclosure leads to severe financial loss or regulatory violations.
- **Internal:** Disclosure results in moderate harm and requires protection from tampering.

Public: Data is publicly accessible and requires basic protection for availability and content integrity. •

Part 3: Development of Security Policies

3.1 Data Classification and Handling Policy

- **Scope:** All employees, contractors, and systems handling bank data.
- **Objective:** Ensure all data is classified and protected according to local regulations (PDPL) and international standards (PCI DSS).

- **Key Controls:** Define classification levels (Confidential, Internal, Public) and impact assessment, apply data masking to show sensitive data only to authorized personnel, and implement retention and secure disposal procedures for confidential data according to regulatory timelines.

3.2 Access Control Policy

- **Scope:** All information systems, applications, and user accounts, especially those interacting with core banking systems.
- **Objective:** Apply the Principle of Least Privilege and Separation of Duties to prevent unauthorized use.
- **Key Controls:** Implement SoD to ensure no single employee can complete all steps of critical transactions, use Privileged Access Management (PAM), and enforce Multi-Factor Authentication (MFA) for all users accessing sensitive systems.

3.3 Patch and Vulnerability Management Policy

- **Scope:** All servers, ATMs, workstations, network devices, and critical applications.
- **Objective:** Reduce the bank's attack surface by promptly addressing vulnerabilities.
- **Key Controls:** Enforce strict timelines—critical vulnerabilities in internet-facing systems must be patched within 48 hours, high-risk internal vulnerabilities within 7 days. All updates must be tested in a simulated environment before deployment.

3.4 Incident Response Policy (IRP)

- **Scope:** Any event affecting the confidentiality, integrity, or availability of bank systems or data.
- **Objective:** Establish a documented incident response program (IRP) ensuring organized handling of security events in line with SAMA regulations.
- **Key Controls:** Clearly define a Computer Security Incident Response Team (CSIRT), document a structured plan (Detection, Containment, Eradication, Recovery, Lessons Learned), preserve evidence for forensic investigations, and comply with SAMA reporting requirements and customer notifications when necessary.

3.5 Business Continuity and Disaster Recovery Policy (BC/DR)

- **Scope:** Core banking systems, payment gateways, and customer transaction processing.
- **Objective:** Ensure service continuity and minimize data loss during disasters or attacks.
- **Key Controls:** Define Recovery Time Objective (RTO) for core systems not to exceed 1 hour, Recovery Point Objective (RPO) for critical data (core ledger) to ensure near-zero loss. Conduct a full annual test of the DR site and ensure geographically distant facilities to avoid regional disasters.

Part 4: Mapping of Business Objectives to Security Goals

4.1 Overview

To ensure the cybersecurity program adds value to the Saudi Investment Bank (SIB), security initiatives must align directly with the bank's strategic business objectives. This section maps the bank's core business goals to specific security objectives (Confidentiality, Integrity, Availability) and identifies the enabling policies designed in Part 3.

4.2 Strategic Alignment Matrix

Business Objective 1: Regulatory Compliance and Legal Adherence

- **Business Context:** As a financial institution, SIB must strictly adhere to SAMA regulations, the Personal Data Protection Law (PDPL), and international standards like PCI DSS to avoid heavy fines and legal sanctions.
- **Security Goal (Primary):** Confidentiality & Integrity. ensuring sensitive data is not exposed and that audit trails remain tamper-proof.
- **Enabling Security Policies:**
 1. Data Classification and Handling Policy: Ensures PII and financial data are identified and protected according to legal standards.
 2. Access Control Policy: Enforces "Least Privilege" to satisfy regulatory requirements for data access restrictions.

Business Objective 2: Maintaining Customer Trust and Brand Reputation

- **Business Context:** The bank's reputation relies on the privacy of its clients. A single data breach involving high-profile corporate clients or retail customers could lead to a loss of trust and market share.
- **Security Goal (Primary):** Confidentiality. Preventing unauthorized disclosure of customer financial information and personal data.
- **Enabling Security Policies:**
 1. Incident Response Policy (IRP): Ensures that if a threat occurs, it is contained quickly to minimize public impact and reputational damage.
 2. Patch and Vulnerability Management: Proactively closes security gaps that attackers could exploit to steal data.

Business Objective 3: Ensuring Continuous Digital Banking Operations

- **Business Context:** SIB relies on 24/7 availability of its mobile app, online banking, and payment gateways (SWIFT/SARIE). Downtime results in direct financial loss and customer dissatisfaction.
- **Security Goal (Primary):** Availability. Ensuring systems are resilient against attacks (e.g., Ransomware, DDoS) and technical failures.
- **Enabling Security Policies:**
 1. Business Continuity and Disaster Recovery (BC/DR) Policy: Guarantees that core banking services can be restored within the defined RTO (1 hour) in the event of a major disruption.
 2. Patch Management Policy: Prevents system crashes caused by exploiting unpatched vulnerabilities.

Business Objective 4: Financial Integrity and Fraud Prevention

- **Business Context:** The bank processes massive volumes of transactions daily. It is critical that transaction data is accurate and cannot be manipulated by insiders or external attackers (e.g., altering a transfer amount).
- **Security Goal (Primary):** Integrity. Ensuring that data remains accurate, consistent, and trustworthy throughout its lifecycle.
- **Enabling Security Policies:**
 1. **Access Control Policy:** Implements Separation of Duties (SoD) and Multi-Factor Authentication (MFA) to prevent unauthorized transaction approvals or ledger manipulation.
 2. **Data Classification Policy:** Ensures that "Core Banking Ledger" data is treated with the highest integrity safeguards.

4.3 Summary of Alignment

By linking these objectives, the cybersecurity program shifts from being a cost center to a business enabler. It directly supports SIB's ability to operate legally, protect its revenue streams, and maintain the trust of its stakeholders.

Part 5: Security Program Design and Governance

5.1 Program Governance and Structure

To ensure the effectiveness of the cybersecurity program at Saudi Investment Bank (SIB), a robust governance structure has been established. This structure guarantees that security decisions align with business goals and that accountability is clearly defined across the organization.

The governance hierarchy is led by the Cybersecurity Steering Committee, composed of C-level executives (CEO, CFO, CIO) and the CISO. This committee meets quarterly to review security risks, approve budget allocations, and ensure strategic alignment with business objectives. Reporting to this committee is the Chief Information Security Officer (CISO), who is responsible for the overall security strategy. The CISO reports directly to the CEO to ensure independence from IT operations and unbiased risk reporting. Supporting the CISO is the Security Operations Team, which is tasked with day-to-day monitoring (SOC), executing incident response plans (CSIRT), and managing vulnerability assessments.

5.2 Alignment with NIST Cybersecurity Framework (CSF)

The SIB cybersecurity program is designed based on the NIST CSF version 2.0 to ensure comprehensive coverage of cybersecurity risks. The program implements the five core functions of the framework as follows:

1. Identify

The bank maintains a real-time inventory of all Critical Information Assets, such as the Core Banking Ledger and SWIFT Gateway, to ensure full visibility of the attack surface. Furthermore, all data is classified into three categories (Confidential, Internal, Public) in strict compliance with the Personal Data Protection Law (PDPL). Regular quarterly risk assessments are conducted to proactively identify new threats to digital banking services.

2. Protect

To prevent unauthorized access, the bank enforces a strict Access Control Policy that

mandates Multi-Factor Authentication (MFA) and Separation of Duties (SoD) for all financial transactions. Data protection is ensured through strong encryption (AES-256) for customer data both at rest and in transit. Additionally, a rigorous Patch Management process is in place to fix critical vulnerabilities within 48 hours of discovery.

3. Detect

The Detect function is crucial for enabling the timely discovery of cybersecurity events. SIB implements controls to continuously monitor the environment and analyze anomalous activity. A 24/7 Security Operations Center (SOC) is established to maintain vigilance, continuously monitoring network traffic, systems, and user behavior, especially around high-value assets like the Core Banking Ledger and Payment Gateways. This continuous oversight is coupled with the use of advanced tools like Security Information and Event Management (SIEM) and User and Entity Behavior Analytics (UEBA) to identify deviations from baseline activity, such as unusually large transfer amounts or privileged access attempts outside of business hours, which fall under Adverse Event Analysis (DE.AE). Furthermore, routine, automated Vulnerability Management (DE.VM) scans are executed across all infrastructure to detect unpatched systems, ensuring that potential gaps are found before they can be exploited, directly supporting the bank's Patch and Vulnerability Management Policy.

4. Respond

The Respond function ensures rapid and effective action is taken upon the detection of a security event to contain the threat and mitigate harm. SIB achieves this through the execution of its documented Incident Response Policy (IRP). The response lifecycle is structured around Incident Management (RS.MA), covering detection, containment, eradication, recovery, and lessons learned. Centralized emergency alerting and a defined escalation chain from the SOC to the CISO and the Crisis Management Team (CMT) establish the foundation for Response Reporting and Communication (RS.CO). During an incident, the CSIRT conducts Incident Analysis (RS.AN), investigating the root cause, containing the attack, and ensuring proper evidence preservation for legal and forensic purposes. Crucially, the Compliance & Legal Officer ensures that all mandatory SAMA and PDPL notifications are filed within required timelines, which is part of Incident Mitigation (RS.MI).

5. Recover

The Recover function focuses on maintaining resilience and restoring systems and data to a functional state following a security incident or disaster. This function is guided by the Business Continuity and Disaster Recovery (BC/DR) Policy. The execution of the comprehensive BC/DR Plan, including the defined Failover Procedure to the Hot or Warm Alternate Site Architecture, serves as the core of Incident Recovery Plan Execution (RC.RP). Recovery efforts are strictly prioritized based on the RTO (Recovery Time Objective) and RPO (Recovery Point Objective) defined in the Business Impact Analysis (BIA), such as the <1 Hour RTO for the Core Banking Ledger. Furthermore, Incident Recovery Communication (RC.CO) ensures that all recovery activities are transparently communicated to internal and external stakeholders, focusing on reputation management. Finally, continuous Improvement (RC.IM) is ensured through mandatory annual Full DR Drills and quarterly Tabletop Exercises to validate the plan's effectiveness and incorporate lessons learned.

Part 6: Evaluation Framework

To measure the effectiveness and maturity of the Saudi Investment Bank's (SIB) cybersecurity program, an evaluation framework will be implemented using a combination of Cybersecurity Audits and the Capability Maturity Model (CMM), mapped against the NIST Cybersecurity Framework (CSF) v2.0 5 core functions.

6.1 Cybersecurity Audit

The cybersecurity audit focuses on testing the implementation of security controls and ensuring compliance with regulatory requirements (SAMA, PDPL, PCI DSS) and our bank's own security policies.

Audit scope	objective	Measurement Metric	audit frequency
Identify	Validate completeness and accuracy of Critical Information Asset (CIA) Inventory	percentage of all properly documented and classified critical assets	Annually (Full), Quarterly (Spot Check)
Protect	Verify enforcement of MFA/SoD on sensitive systems and encryption standards (AES-256)	- Check all critical systems enforcing MFA properly - Regular testing and compliance checks	Annually
Detect	Review SOC operations and the effectiveness of SIEM/UEBA rules in identifying anomalous activity.	- Check average time to detect a simulated threat. - check False Positive Rate	Semi-Annually
Respond	Test Incident Response Policy (IRP) activation and SAMA/PDPL notification timeliness.	- The time it takes to contain a threat - percentage of all regulatory reports filed on time	Semi-Annually
Recover	Validate the BC/DR Plan's ability to meet defined RTO/RPO objectives for critical systems.	RTO/RPO achievement in a Full Disaster Recovery Drill	Annually (Full DR Drill)

Figure 1 cybersecurity program audit table

6.2 Capability Maturity Model (CMM)

The CMM assesses the maturity of the security processes and documentation for the five NIST CSF functions, indicating the program's evolution from ad-hoc to optimized.

TABLE 4-1 Capability Maturity Model (CMM) Scale

Level	State	Description
0	Nonexistent	The organization is unaware of the need for policies or processes.
1	Ad hoc	There are no documented policies or processes; there is sporadic activity.
2	Repeatable	Policies and processes are not fully documented; however, the activities occur on a regular basis.
3	Defined process	Policies and processes are documented and standardized; there is an active commitment to implementation.
4	Managed	Policies and processes are well defined, implemented, measured, and tested.
5	Optimized	Policies and process are well understood and have been fully integrated into the organizational culture.

Figure 2 capability maturity model, from “developing cyber security program and policies” book.

6.2.2 Maturity Targets for SIB's Program

Based on Part 5, our SIB's program demonstrates characteristics that is most applicable to be placed at Level 3, although we aim towards being placed at Level 4-5 as we continue to improve on our Cybersecurity program.

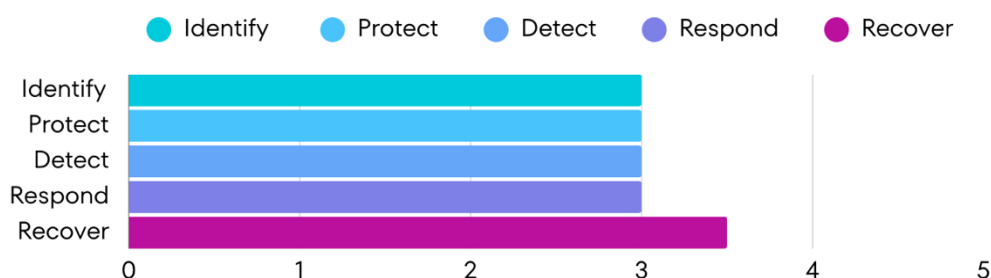


Figure 3 cybersecurity program capability maturity model

6.3 Continuous Improvement (RC.IM)

we aim for the continuous improvement (RC.IM) of our cybersecurity program in the future, as we accumulate more experience. To ensure that improvements happen well follow those steps:

- **Audit Findings:** Gaps identified by the annual audit and quarterly compliance checks directly feed into the risk register and are prioritized by the Cybersecurity Steering Committee.
- **CMM Score:** A low CMM score in any function (e.g., Detect) indicates a need for process formalization and resource allocation, which the CISO can present to the Steering Committee for budget approval.
- **Lessons Learned:** Mandatory "Lessons Learned" reviews after every incident or DR drill ensure that weaknesses identified in the Respond or Recover functions are fixed by updating the associated policies and controls.

Part 7: Business Continuity & Disaster Recovery (BC/DR) Plan

The Business Continuity & Disaster Recovery (BC/DR) Plan for the Saudi Investment Bank (SIB) ensures that critical banking services remain available or can be restored within acceptable timeframes in the event of a disruption. The plan is designed to support regulatory compliance, maintain customer trust, and protect the bank's financial stability.

7.1 Business Impact Analysis (BIA)

The Business Impact Analysis identifies critical systems within SIB, evaluates the operational impact of downtime, and defines the recovery objectives required to maintain acceptable levels of service and regulatory compliance.

Critical Assets and Recovery Requirements

Critical Function / Asset	Impact of Downtime	RTO (Recovery Time Objective)	RPO (Recovery Point Objective)
Core Banking Ledger	High: Halted transactions , corrupted balances, regulatory violations	<1Hour	Near-Zero (Synchronous Replication)
Payment Gateways (SWIFT/SARIE)	High: Inability to process transfers; financial penalties	< 2Hours	< 15 minutes

Mobile & Online Banking	High: Customer dissatisfaction and loss of trust	4 Hours	1 Hour
CRM System	Moderate: Delayed compliance and customer-service impact	8 Hours	< 30 minutes
Internal Audit Reports	Moderate: Delayed regulatory submissions	24 Hours	24 Hours
Investor Relations website	Low: Minimal operational impact	48 Hours	24 Hours

7.2 Recovery Strategy

7.2.1 Backup Strategy

The bank adopts a multi-layered backup model based on best practices and regulatory expectations:

- **3-2-1 Backup Rule:**
 - 3 copies of all critical data
 - 2 different storage media (SAN + off-site Cloud)
 - 1 copy stored in a geographically remote location
- **Backup Types Implemented:**
 - **Synchronous replication** for Core Banking Ledger and SWIFT for near-zero RPO
 - **Asynchronous replication** for CRM and mobile banking
 - **Daily encrypted backups** stored off-site and retained per PDPL mandates
 - **Monthly archival backups** for compliance and audit cycles

7.2.2 Alternate Site Architecture

To ensure high service continuity, SIB maintains:

- **Hot Site (Primary DR Data Center):**
Fully operational infrastructure capable of immediate takeover for the Core Banking Ledger and SWIFT.
- **Warm Site:**
Pre-configured systems for CRM and internal services that can be activated within defined RTOs.

- **Cloud-based Recovery:**
Used for low-sensitivity, high-availability assets such as the public Investor Relations website.

7.2.3 Communication & Escalation Plan

In the event of a disaster, activation triggers centralized communication through:

- Internal emergency alerting (SMS, Email, Secure Portal)
- A dedicated emergency Microsoft Teams channel
- A crisis hotline for leadership coordination

A clear escalation chain: **SOC → CISO → CEO → Full Crisis Management Team** •

7.3 Crisis Management Team (CMT)

The Crisis Management Team is responsible for leading, coordinating, and executing all response and recovery activities during a major disruption.

7.3.1 Organizational Structure

The following roles form the CMT responsible for BC/DR activation and overall coordination:

- **Chief Executive Officer (CEO) – Disaster Declaration Authority**
- **Chief Information Security Officer (CISO) – Cyber Crisis Lead**
- **IT Recovery Lead – Technical Restoration Manager**
- **SOC Manager – Incident Detection & Escalation**
- **Compliance & Legal Officer – Regulatory Liaison**
- **Public Relations (PR) Lead – External Communication Manager**

7.3.2 Roles and Responsibilities

Chief Executive Officer (CEO) – Disaster Declaration Authority Responsibilities:

- Officially declares activation and deactivation of disaster mode.
- Approves resource allocation and major recovery decisions.
- Communicates with the Board and senior stakeholders regarding the incident impact.
- Provides executive oversight and ensures alignment with business priorities during the crisis.

Chief Information Security Officer (CISO) – Cyber Crisis Lead Responsibilities:

- Leads the cybersecurity and technical response during the disaster.

- Oversees communication with regulatory entities such as SAMA and PDPL authorities.
- Ensures proper forensic evidence preservation in the event of a cyberattack.
- Supervises SOC and IT recovery teams and approves recovery priorities based on risk assessment.

IT Recovery Lead – Technical Restoration Manager

Responsibilities:

- Executes system failover to the Disaster Recovery (DR) site.
- Validates the integrity, accuracy, and availability of restored systems.
- Leads failback operations and coordinates the safe return to production systems.
- Manages technical recovery tasks across infrastructure, application, and network teams.

SOC Manager – Incident Detection & Escalation

Responsibilities:

- Detects and classifies incidents affecting system availability, confidentiality, or integrity.
- Escalates incidents to the CISO and triggers internal alerting procedures.
- Provides continuous monitoring and analysis during the crisis.
- Supports forensic investigations by preserving logs, alerts, and event evidence.

Compliance & Legal Officer – Regulatory Liaison

Responsibilities:

- Ensures compliance with SAMA, PDPL, PCI DSS, and other regulatory standards during the incident.
- Files mandatory notifications and reports to regulatory bodies within required timelines.
- Ensures legal accuracy and adherence to regulatory obligations throughout recovery activities.
- Maintains documentation and audit trails for post-incident reviews and external audits.

Public Relations (PR) Lead – External Communication Manager

Responsibilities:

- Manages external communication with media, partners, and the general public.
- Protects the bank's reputation by ensuring accurate and controlled messaging.
- Coordinates customer notifications in case of data disclosure or service disruption.

- Aligns all public statements with CISO and Legal/Compliance teams to prevent misinformation.

7.4 Plan Activation & Operations

7.4.1 Activation Criteria

The BC/DR plan is activated when:

- Core banking or payment systems experience outages exceeding their defined RTO.
- Cyberattacks (e.g., ransomware, DDoS) significantly impact system availability or data integrity.
- Physical disasters (fire, flood, power failure) disrupt the primary data center.
- Severe network failures prevent the continuation of critical banking services.

7.4.2 Failover Procedure (Switching to DR Site)

1. The SOC detects and classifies the incident severity.
2. The CISO escalates the incident to senior leadership.
3. The CEO issues an official *Disaster Declaration*.
4. The IT Recovery Lead performs:
 - a. System failover to the DR site
 - b. Activation of replicated environments
 - c. Verification of data consistency and system stability
5. The Crisis Management Team communicates status updates to all relevant departments.

7.4.3 Failback Procedure (Return to Normal Operations)

1. Validate the stability and readiness of the primary data center.
2. Synchronize data from the DR site back to the primary production environment.
3. Conduct integrity and availability tests on restored services.
4. Gradually migrate services back to the primary environment in a controlled manner.
5. The CMT formally approves the completion of failback operations and exits disaster mode.

7.5 Testing & Maintenance

7.5.1 Testing Program

Regular testing ensures the effectiveness of BC/DR controls:

Test Type	Description	Frequency
Tabletop Exercise	Scenario-based discussion without system activation	Quarterly
Functional Test	Validates a specific component (e.g., SWIFT failover)	Semi-annually
Full DR Drill	Complete activation of the DR site	Annually
Backup Restoration Test	Validates backup integrity and recoverability	Monthly

7.5.2 Maintenance Requirements

- Review and update the BC/DR plan annually.
- Update team contact lists and escalation paths quarterly.
- Conduct lessons-learned reviews after every real incident and incorporate improvements.
- Reassess RTO/RPO whenever new systems or critical services are introduced or significantly changed.

Part 8: Recommendations and Future Improvements

Based on the current state of the SIB Cybersecurity Program (Program Governance, Policies, BC/DR Plan, and Level 3 CMM Maturity Target), the following recommendations are proposed to enhance the security posture, increase process automation, and achieve the target of **Level 4 (Managed)** maturity.

8.1 Enhance the 'Detect' Function and Reduce Response Time (Focus: Automation)

The Detect function currently relies on a 24/7 SOC with SIEM/UEBA. To move beyond Level 3 (Defined Process) and reduce the **Average Time to Detect (ATTD)**, automation is critical.

- **Recommendation 1: Implement Security Orchestration, Automation, and Response (SOAR).**
 - **Action:** Integrate the SIEM system with a SOAR platform to automate repetitive tasks, such as initial alert triage, threat enrichment, and the automated containment of known malicious endpoints.
 - **Goal:** Drastically reduce the **Mean Time to Detect (MTTD)** and the **Mean Time to Contain (MTTC)**, directly improving the effectiveness metric of the **Incident Response Policy (IRP)**.
 - **CMM Impact:** Moves the **Detect** and **Respond** functions toward **Level 4 (Managed)** maturity by implementing a measured and automated process.

- **Recommendation 2: Enhance UEBA Coverage for Core Systems.**
 - **Action:** Expand User and Entity Behavior Analytics (UEBA) to specifically model and monitor behavior across the **Core Banking Ledger** and **SWIFT Systems**.
 - **Goal:** Proactively identify subtle insider threats or sophisticated external attacks focused on financial fraud (Business Objective 4: Financial Integrity) by detecting anomalous privileged access or large transaction deviations.

8.2 Formalize 'Protect' Enforcement (Focus: Measurement and Testing)

While policies are defined (Level 3) , future improvement must focus on verification and management (Level 4).

- **Recommendation 3: Formalize Privileged Access Management (PAM) Audits.**
 - **Action:** Implement monthly, automated audits to verify that the **Principle of Least Privilege** and **Separation of Duties (SoD)** are enforced across all critical systems, specifically targeting users with access to the **Core Banking Ledger**.
 - **Goal:** Ensure 100% compliance with the **Access Control Policy** and the **Protect** function's objective of verifying enforcement of MFA/SoD.
 - **CMM Impact:** Achieves **Level 4 (Managed)** for the **Protect** function by enforcing regular measurement and testing of controls.
- **Recommendation 4: Establish a Bug Bounty Program for Digital Banking Platforms.**
 - **Action:** Launch a managed external bug bounty program focused on the Mobile and Online Banking applications.
 - **Goal:** Leverage the security community to proactively find critical vulnerabilities that internal testing may miss, supporting the **Patch and Vulnerability Management Policy** objective to reduce the bank's attack surface and maintain **Customer Trust** (Business Objective 2).

8.3 Optimize 'Recover' Capabilities (Focus: Scope and Documentation)

The BC/DR Plan is comprehensive, but expansion ensures true optimization.

- **Recommendation 5: Integrate Supply Chain Risk into BC/DR Testing.**
 - **Action:** Expand the annual **Full DR Drill** to include a simulation of a failure within a critical third-party payment processor or a major cloud service provider.
 - **Goal:** Ensure that the bank can meet RTO/RPO objectives even when dependencies fail, addressing the growing complexity of digital banking and enhancing the resilience of the **Payment Gateways**.
 - **NIST CSF:** Enhances the **Recover (RC.RP)** function by incorporating external dependencies into recovery planning.

- **Recommendation 6: Implement Continuous Policy Review Cycle.**
 - **Action:** Shift policy review from a simple annual update to a continuous process managed by a dedicated governance tool that tracks changes against regulatory updates (SAMA, PDPL).
 - **Goal:** Ensure the entire cybersecurity program remains agile and immediately compliant with new financial and data protection mandates, maintaining **Regulatory Compliance** (Business Objective 1).
 - **CMM Impact:** Drives the entire program towards **Level 5 (Optimized)** maturity by ensuring policies are fully integrated and continually improved based on external factors.